

# AI Governance & Risk Management Program

*NovaTech Solutions (Fictional Organization)*

**Prepared by Dhriti Pandya**

## 1. Executive Summary

For this portfolio project, I assessed how a fictional 500-employee company could manage the risks created by growing use of generative AI across its departments. I identified six major AI risks involving sensitive data, inaccurate outputs, unauthorized AI use, compliance, intellectual property, and AI-generated code. Three of the risks were rated Critical before controls, with Sensitive Data Disclosure receiving the highest inherent score of 25.

Based on the assessment, I developed proposed controls such as an approved-AI-tool process, data loss prevention (DLP), human review requirements, privacy and legal review, secure development checks, and ongoing monitoring. I also created a separate AI Governance & Acceptable Use Policy and connected the program to the NIST AI Risk Management Framework (AI RMF) and NIST Cybersecurity Framework (CSF) 2.0. Because NovaTech is fictional, the controls are proposed rather than implemented, and the residual risk ratings are estimates.

## 2. Organization & AI Environment

NovaTech Solutions is a fictional organization with approximately 500 employees. I used the following departments to create realistic AI use cases and risk scenarios:

- Information Technology - administration, support, and technology operations.
- Human Resources - job descriptions, interview questions, onboarding, and employee information.
- Finance - summaries of monthly reports and internal financial information.
- Marketing - social media, campaign, and advertising content.
- Customer Support - draft responses to customer questions.
- Software Development - sample code, unit tests, documentation, and coding assistance.

The main governance problem is that employees are using or may begin using generative AI before the organization has a mature approval process, clear data-handling rules, or consistent oversight.

## 3. Risk Assessment Methodology

I used a qualitative 5x5 likelihood-and-impact method. Likelihood and impact are each scored from 1 to 5, and the two values are multiplied to create the risk score. The rating bands used in this project are: Low (1-4), Medium (5-9), High (10-16), and Critical (17-25).

Inherent risk represents the level of risk before the proposed controls. Residual risk represents my estimate of the risk that could remain after the proposed controls are operating effectively. The residual scores are not control-test results.

## 4. AI Risk Register

| ID      | Risk                               | L | I | Inherent      | Treatment | Key Controls                                   | RL | RI | Residual   | Proposed Risk Owner    |
|---------|------------------------------------|---|---|---------------|-----------|------------------------------------------------|----|----|------------|------------------------|
| AI-R001 | Sensitive Data Disclosure          | 5 | 5 | 25 / Critical | Mitigate  | DLP; data classification; authorized use       | 2  | 5  | 10 / High  | Information Security   |
| AI-R002 | Inaccurate AI Output               | 4 | 4 | 16 / High     | Mitigate  | Finance verification; restricted high-risk use | 2  | 4  | 8 / Medium | Finance                |
| AI-R003 | Shadow AI / Unauthorized AI Use    | 5 | 4 | 20 / Critical | Mitigate  | Tool approval; blocking; AI-use monitoring     | 2  | 4  | 8 / Medium | Information Security   |
| AI-R004 | Compliance & Regulatory Violations | 4 | 5 | 20 / Critical | Mitigate  | De-identification; Privacy/Legal review        | 2  | 5  | 10 / High  | Privacy / Legal        |
| AI-R005 | Intellectual Property Exposure     | 4 | 5 | 20 / Critical | Mitigate  | Code DLP; approved coding assistants           | 2  | 5  | 10 / High  | Engineering Leadership |
| AI-R006 | AI-Generated Content Contamination | 4 | 4 | 16 / High     | Mitigate  | Developer review; security/quality testing     | 2  | 4  | 8 / Medium | Engineering            |

## 5. Risk Treatment & Controls

### AI-R001 - Sensitive Data Disclosure

Proposed control: Implement DLP controls to detect and block unauthorized submission of sensitive or restricted data to generative AI systems. Require employees to classify information and confirm that the AI use case is authorized before submitting organizational data.

Control type: Preventive

Proposed control owner: Information Security; IT support

Example evidence: DLP configuration, blocked-event logs, incident reports, classification workflow records, and training records.

Residual-risk rationale: Likelihood is reduced because unauthorized submissions are more likely to be prevented or detected. Impact remains Severe because a successful disclosure could still be significant.

### AI-R002 - Inaccurate AI Output

Proposed control: Require AI-generated financial summaries, analyses, or recommendations to be checked against authoritative source data by an authorized Finance reviewer. Restrict high-risk financial activities from relying on AI as the authoritative source.

Control type: Preventive

Proposed control owner: Finance; InfoSec guidance

Example evidence: Review/approval records, version history, workflow records, restricted-use requirements, and training/communications.

Residual-risk rationale: Independent verification reduces the chance that incorrect AI output becomes official information, while the potential business impact remains meaningful.

### **AI-R003 - Shadow AI / Unauthorized AI Use**

Proposed control: Require Information Security approval before business use of new AI tools. Block known unapproved AI services where practical and monitor AI-related traffic or account creation.

Control type: Preventive + Detective

Proposed control owner: Information Security; IT support

Example evidence: Approved-tool inventory, approval tickets, filtering configuration, monitoring alerts/logs, and investigation tickets.

Residual-risk rationale: Approval, blocking, and monitoring reduce the likelihood of unmanaged AI use but cannot eliminate it completely.

### **AI-R004 - Compliance & Regulatory Violations**

Proposed control: Require identifiers to be removed or masked before approved AI use when appropriate. Employee-information AI use cases must receive documented Privacy/Legal review to determine applicable requirements and authorization.

Control type: Preventive

Proposed control owner: Privacy/Legal; HR process support

Example evidence: AI-use approvals, Privacy/Legal review records, data-handling requirements, de-identification samples, and technical logs when applicable.

Residual-risk rationale: Review and data minimization reduce likelihood, but the impact remains Severe because employee-data misuse could create major legal, privacy, or trust consequences.

### **AI-R005 - Intellectual Property Exposure**

Proposed control: Use technical controls to detect or block unauthorized submission of proprietary source code to external AI tools. Developers may use proprietary code only with organization-approved AI coding assistants that have been reviewed for security, privacy, and data handling.

Control type: Preventive

Proposed control owner: Engineering; Information Security support

Example evidence: DLP/security configuration, blocked-event logs, approved-tool inventory, security review, developer access records, and training.

Residual-risk rationale: Controls reduce likelihood, but the impact remains Severe because exposure of proprietary code or algorithms could still cause major business harm.

### **AI-R006 - AI-Generated Content Contamination**

Proposed control: Require qualified developer review before AI-generated code is merged. Require static analysis, vulnerability scanning, applicable unit tests, and other required quality checks before production deployment.

Control type: Preventive

Proposed control owner: Engineering; InfoSec/DevSecOps support

Example evidence: Pull-request approvals, branch-protection settings, CI/CD configuration, static-analysis results, vulnerability scans, unit-test results, and deployment records.

Residual-risk rationale: Human review and automated testing together reduce the likelihood that insecure AI-generated code reaches production.

## 6. AI Governance Program Summary

The governance program connects the risk assessment to practical organizational requirements. The separate AI Governance & Acceptable Use Policy covers approved AI tools, data handling, human oversight, prohibited uses, reporting, and review responsibilities.

- Information Security reviews AI tools and security controls.
- Privacy/Legal reviews applicable AI use cases for privacy, legal, regulatory, and contractual requirements.
- Employees and other AI users are responsible for using approved tools, protecting organizational data, following restrictions, and reporting concerns.
- Tool approval does not automatically mean every type of data or every use case is approved.
- Business-critical AI output requires meaningful review by a qualified person before official use.
- The policy should be formally reviewed at least annually and earlier after major incidents, significant regulatory changes, or new high-risk AI uses.

## 7. NIST AI RMF Mapping

| AI RMF Function | How I Applied It in This Project                                                                                               |
|-----------------|--------------------------------------------------------------------------------------------------------------------------------|
| GOVERN          | Developed governance requirements, roles, responsibilities, an AI tool approval process, and a separate acceptable-use policy. |
| MAP             | Identified AI use cases, departments, data types, affected people/systems, and potential impacts.                              |
| MEASURE         | Assessed six AI risks using likelihood and impact and estimated inherent and residual risk.                                    |
| MANAGE          | Selected treatments and controls, developed recommendations, defined monitoring, and considered residual-risk decisions.       |

## 8. NIST CSF 2.0 Mapping

| CSF 2.0 Function | Project Connection                                                                                                |
|------------------|-------------------------------------------------------------------------------------------------------------------|
| GOVERN           | AI policy, responsibilities, tool approval, risk ownership, and governance decisions.                             |
| IDENTIFY         | AI use cases, organizational data, affected systems, and the six identified AI risks.                             |
| PROTECT          | Approved-tool restrictions, DLP blocking, data-handling rules, human review, and secure development checks.       |
| DETECT           | Monitoring for shadow AI, DLP/security alerts, and review of suspicious AI-related activity.                      |
| RESPOND          | Prompt reporting, containment, investigation, impact assessment, and coordination with Privacy/Legal when needed. |
| RECOVER          | Secure restoration of affected systems/workflows, lessons learned, and updates to policy, controls, and training. |

Some controls support more than one function. For example, DLP can support PROTECT when it blocks a submission and DETECT when it generates an alert.

## 9. Recommendations & Implementation Roadmap

| Recommendation                                                                                                               | Priority | Proposed Owner(s)                                    | Target     |
|------------------------------------------------------------------------------------------------------------------------------|----------|------------------------------------------------------|------------|
| Establish and enforce an approved AI tools program, including intake/approval and restrictions on known unapproved services. | High     | Information Security; IT support                     | 0-30 days  |
| Issue the AI Governance & Acceptable Use Policy and initial communication.                                                   | High     | Information Security; Privacy/Legal                  | 0-30 days  |
| Implement DLP and AI-use monitoring for sensitive data, employee/customer information, and proprietary code.                 | High     | Information Security; IT/Security Operations support | 30-60 days |
| Provide employee AI-use training covering approved tools, data handling, human review, and incident reporting.               | High     | HR; Information Security                             | 30-60 days |

### Management Monitoring

I would recommend a monthly management review of four simple metrics:

- Unapproved AI usage attempts - a risk indicator for shadow AI.
- DLP alerts involving AI tools - a risk indicator for attempted sensitive-data submission.
- AI policy training completion percentage - a governance/compliance performance metric.
- Open High or Critical AI risks - visibility into unresolved significant risk.

A major incident or significant change in risk should be escalated when it occurs rather than waiting for the monthly review.

### Residual Risk & Risk Acceptance

A High residual risk does not automatically mean controls must be added until the rating becomes Medium or Low. Some risks can retain severe potential impact even when controls reduce their likelihood. Remaining risk should be compared with the organization's risk appetite and tolerance. The appropriate risk owner or authorized leadership should decide whether the risk is accepted, further mitigated, avoided, or transferred. For example, I assigned AI-R005 to Engineering leadership for management review because that group is accountable for the business use and protection of proprietary source code, while Information Security/GRC would support the decision with risk analysis and security recommendations.

## 10. What I Learned

Before this project, I understood GRC mainly as policy writing and compliance checklists. Through this project, I learned that AI governance requires understanding how AI is actually used across an organization, identifying the risks created by those use cases, and designing controls that are practical for real business teams.

I also learned how to assess risks using likelihood and impact, distinguish between inherent and residual risk, and select controls that meaningfully reduce risk rather than simply documenting it. Applying the NIST AI RMF and NIST CSF 2.0 also helped me understand how frameworks can turn risk-management concepts into a structured governance approach.

## Portfolio Note

NovaTech Solutions is a fictional organization created for this educational cybersecurity GRC portfolio project. The controls in this report are proposed controls, not production implementations. Residual risk ratings are estimates based on the fictional scenario and are not results from control testing.